

Enumeração e Reconhecimento em Pentest

As primeiras etapas de um teste de penetração, enumeração e reconhecimento são essenciais para entender a superfície de ataque do alvo.

A enumeração coleta informações sobre os sistemas, serviços e usuários do alvo, enquanto o reconhecimento examina a infraestrutura de rede, aplicativos e configurações para encontrar vulnerabilidades.

```
31337
scanme.nmap.org d0ze
1.01 ( http://www.insecure.org/nmap/ ) at 2006-03-20
Ports on scanme.nmap.org (205.217.153.62):
Ports scanned but not shown below are in state: filtered
SERVICE VERSION
ssh      OpenSSH 3.9p1 (protocol 1.99)
smtp     Postfix smtpd
domain   ISC Bind 9.2.1
gopher
http     Apache httpd 2.0.52 ((Fedora))
auth
general purpose
2.6.X
Linux 2.6.0 - 2.6.11
Days (since Wed Feb 22 11:39:16 2006)

Ports on d0ze.internal (192.168.12.3):
Ports scanned but not shown below are in state: closed)
SERVICE VERSION
ftp       Serv-U ftpd 4.0
smtp      IMail NT-ESMTP 7.15 2015-2
http      Microsoft IIS webserver 5.0
pop3      IMail pop3d 7.15 931-1
mstask    Microsoft mstask (task server - c:\win
netbios-ssn
microsoft-ds Microsoft Windows XP microsoft-ds
msrpc     Microsoft Windows RPC
vnc-http  Ultr@VNC (Resolution 1024x800; VNC TCP
):A0:CC:51:72:7E (Lite-on Communications)
general purpose
Microsoft Windows NT/2K/XP
Microsoft Windows 2000 Professional
OS: Windows

2 IP addresses (2 hosts up) scanned in 42.291 seconds
http://nmap-misc/Screenshots/042006#
```

Conceitos básicos de enumeração

1

1. Coleta de Informações

Enumeração é o processo de reunir informações sobre um alvo, como endereços IP, serviços em execução, usuários e grupos.

2

2. Descoberta de Recursos

Identifica os serviços, sistemas e dispositivos que compõem um alvo, incluindo servidores, impressoras, roteadores e firewalls.

3

3. Análise de Vulnerabilidades

A enumeração fornece informações sobre os serviços e softwares usados pelo alvo, ajudando na identificação de potenciais pontos fracos.

4

4. Mapeamento de Ataque

As informações coletadas durante a enumeração permitem que os pentesters planejem e implementem ataques direcionados de forma mais eficaz.



Enumeração Passiva



1

Coleta de Informações Públicas

Envolve a busca por informações disponíveis publicamente, como registros de domínio, sites da empresa, redes sociais e perfis profissionais.

2

Análise de Dados Abertos

Explorar dados disponíveis publicamente para identificar informações valiosas sobre a organização e seus sistemas.

3

Ferramentas de Reconhecimento

Utilização de ferramentas como Shodan, Censys e Google Hacking Database (GHDB) para encontrar serviços e informações ocultas.

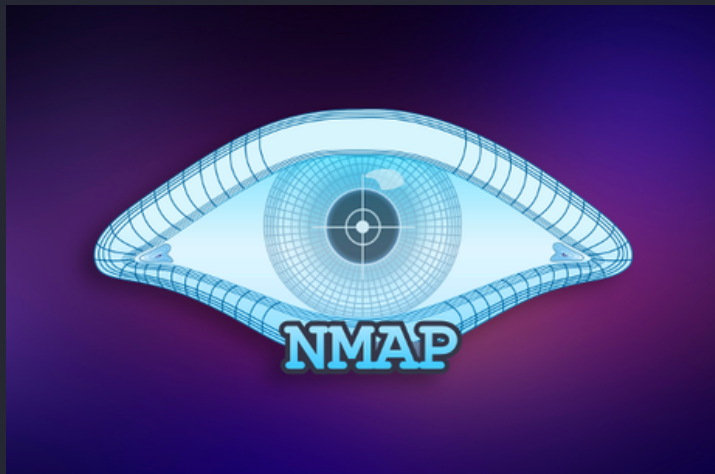
Enumeração Ativa

A enumeração ativa se caracteriza por interagir ativamente com o alvo, solicitando informações e explorando serviços.



Esse tipo de enumeração pode revelar informações valiosas sobre o sistema, mas também pode ser detectada e gerar alertas de segurança.

Técnicas de enumeração ativa



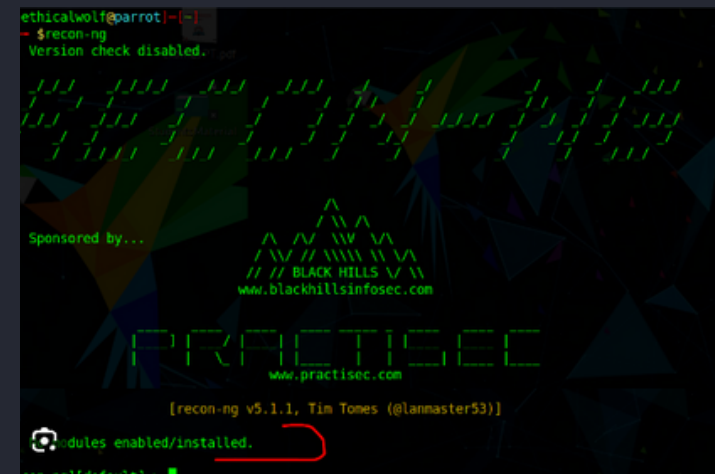
Escaneio de portas

Essa técnica procura por portas abertas em um alvo, revelando serviços em execução e vulnerabilidades potenciais.



Verificação de serviços

Identifica serviços específicos, suas versões e possíveis fraquezas, ajudando a encontrar pontos de entrada para ataques.



Enumeração de usuários e grupos

Coleta informações sobre contas de usuários, grupos e permissões, buscando privilégios e fragilidades no sistema.



Enumeração de recursos compartilhados

Detecta recursos compartilhados, como arquivos, impressoras e pastas, buscando vulnerabilidades que permitem acesso não autorizado.

Ferramentas úteis para enumeração

Nmap

Nmap é uma ferramenta poderosa para escanear redes e identificar serviços em execução em dispositivos. Ele pode ser usado para descobrir portas abertas, sistemas operacionais e aplicativos em execução.

Metasploit

Metasploit é um framework de exploração e teste de penetração que oferece uma variedade de módulos para enumerar informações sobre alvos, incluindo credenciais e vulnerabilidades.

Burp Suite

Burp Suite é uma ferramenta de segurança web que pode ser usada para interceptar e analisar o tráfego HTTP, enumerar serviços web e identificar pontos fracos.

Enum4linux

Enum4linux é uma ferramenta útil para enumerar informações sobre sistemas Linux, como usuários, grupos, compartilhamentos SMB e informações de serviços.



Comandos Nmap



Varredura de portas

O comando **-p** define as portas a serem escaneadas, enquanto o **-sS** especifica o tipo de varredura (SYN).



Escaneando endereços IP

O comando **-T4** aumenta a velocidade do escaneamento, enquanto o **-F** escanea apenas as portas mais comuns.



Scripts Nmap

O comando **-sC** executa scripts padrão, enquanto o **-sV** tenta identificar os serviços em execução.



Saída detalhada

O comando **-oA** salva a saída em um arquivo, enquanto o **-v** fornece um nível de detalhamento adicional.

Comandos Nmap

`nmap <target>`

`nmap -p- <target>`

`nmap -p 22,80,443 <target>`

`nmap -sV <target>`

`nmap -O <target>`

`nmap -A <target>`

`nmap --script=http-vuln* -p 80,443 <target>`

`nmap --script=smb-enum-shares,smb-enum-users -p 445 <target>`

`nmap --script=vuln <target>`

`nmap -sn <target_subnet>` # Exemplo: `nmap -sn 192.168.1.0/24`

`nmap -sS <target>` # SYN Scan

`nmap -sU <target>` # UDP Scan

`nmap -f <target>` # Firewall scan

`nmap -sA <target>` #Portas filtradas pelo firewall

Exemplo de scan completo:

`nmap -p- -A -oN full_scan_results.txt <target>`

Sites Úteis para Enumeração e Reconhecimento

Shodan

Motor de busca especializado em dispositivos conectados à internet. Permite encontrar servidores, câmeras, roteadores e outros dispositivos vulneráveis.

Ajuda na identificação de serviços e tecnologias em execução nas redes.

Censys

Plataforma de pesquisa de infraestrutura de rede que fornece dados sobre endereços IP, domínios e serviços.

Oferece APIs para automatizar a coleta de dados e análise de grandes conjuntos de informações.

Recon-ng

Conjunto de ferramentas de código aberto para enumeração e reconhecimento.

Automatiza a coleta de informações de várias fontes.

Ajuda a reunir dados sobre alvos para análise e planejamento de ataques.

Maltego

Ferramenta de visualização de dados e análise de gráficos para investigar relações entre entidades e dados.

Ajuda a visualizar e analisar dados coletados durante a enumeração e reconhecimento.

Identificação de alvos e mapeamento de rede



1

Coleta de Informações

Comece reunindo informações sobre o alvo, como nome de domínio, endereços IP e informações públicas disponíveis.

2

Varredura de Portas

Utilize ferramentas como o Nmap para escanear as portas abertas do alvo e identificar os serviços que estão em execução.

3

Enumeração de Serviços

Explore os serviços encontrados para descobrir informações adicionais, como versões de software, banners e vulnerabilidades conhecidas.

4

Mapeamento de Rede

Crie um mapa da rede do alvo, incluindo dispositivos, conexões e hierarquia para entender melhor a estrutura da rede.

ATIVIDADE PRÁTICA

Senha Wi-Fi: trocosenhaporcafe
172.20.10.5

ATIVIDADE PRÁTICA

1. Qual serviço está rodando na porta 21 e qual é a sua versão?
2. Qual é a versão do servidor web Nginx rodando na porta 80?
3. Qual é o sistema operacional identificado no servidor?
4. Qual porta está aberta, mas não foi reconhecida corretamente pelo Nmap (dica: a porta 3000)?
5. Quantas portas abertas foram encontradas durante o scan?